

Vendor Due Diligence Policy

Version v1 · Effective 1 July 2025 · Status: published

Owner: Head of Vendor Management · Category: Third-party risk

Applies to: Procurement

Fictional policy written for a software demonstration. Kestrel Mutual is an invented organization. This is not real policy, law or regulatory guidance.

1 Scope

This policy applies to every third party that will receive, store or process Kestrel Mutual customer data.

2 Vendor tiers

2.1 Tiering

Vendor management assigns each vendor a tier when it is added to the vendor register. Tier 1 vendors receive customer data or support a critical service. Tier 2 vendors do neither.

3 Vendor review

3.1 Review before data access

A vendor must complete Kestrel Mutual's vendor review, and hold Approved status in the vendor register, before receiving customer data.

3.2 Review content

Vendor review covers security controls, data location and subprocessors. A completed review is valid for twelve months from its approval date.

3.3 Expired reviews

A vendor whose review has expired is treated as unreviewed until a new review is approved.

3.4 Conditional approval exception

Vendor management may grant Conditional status for up to 90 days while agreed remediation actions are completed. A vendor with Conditional status may receive customer data only if the Chief Information Security Officer approves this in writing, instead of the Approved status that clause 3.1 requires.

4 Contracts

4.1 Data processing terms

A vendor that processes customer data must sign Kestrel Mutual's data processing terms before the first transfer of customer data.

4.2 Subprocessors

A vendor must notify Kestrel Mutual at least 30 days before adding a subprocessor that will handle customer data.